



SOC Task 2

Submitted to: CYArtManager

Date: 15 May, 2026

Environment: Kali Linux on Virtual Machine

Submitted by: Mayuri Thorat

Introduction

Through this training program, I have bridged the gap between theoretical security frameworks and the technical demands of a Security Operations Center. I have mastered the logic of alert prioritization and CVSS risk scoring while integrating industry-standard frameworks like MITRE ATT&CK and NIST to categorize threats with precision. By executing full-scale incident response lifecycles, I have gained hands-on proficiency with essential SOC tools including Wazuh, TheHive, and Velociraptor. This experience culminated in a capstone project where I simulated a real-world exploit, managed the technical response, and produced professional documentation for both technical and executive stakeholders, establishing a robust foundation in modern defensive operations.

Task 1: Alert Priority Levels and Risk Assessment

Overview

In this task, I focused on mastering the methodologies used to categorize and prioritize security alerts within a **Security Operations Center (SOC)**. Understanding how to differentiate between a minor anomaly and a catastrophic breach is critical for ensuring that high-risk threats are mitigated before they can cause significant business impact.

Core Concepts Learned

1. Defining Priority Levels

I learned to classify security incidents into four primary tiers based on the intersection of **Impact** and **Urgency**:

- **Critical:** Incidents requiring immediate intervention, such as active ransomware encryption or a total service disruption.
- **High:** Serious threats like unauthorized administrative access or the discovery of a backdoor on a sensitive system.
- **Medium:** Issues that pose a potential risk but are currently contained, such as a single workstation infected with non-spreading malware.



- **Low:** Minor deviations or policy violations, such as a user failing a login attempt once or an outdated software version on a non-critical asset.

2. Assignment Criteria and Logic

I explored the variables used to assign these priorities effectively:

- **Asset Criticality:** I learned that an alert on a **Production Database** carries more weight than the same alert on a **Test VM**.
- **Exploit Likelihood:** I studied how to assess if a vulnerability is being actively exploited in the wild (e.g., using CISA's Known Exploited Vulnerabilities catalog).
- **Business Impact:** I analyzed how technical threats translate into financial or reputational loss, which dictates the speed of the required response.

3. Standardized Scoring Systems (CVSS)

I researched the **Common Vulnerability Scoring System (CVSS)** to understand how risk is quantified. I focused on:

Base Metrics: Exploitability and Impact.

Temporal & Environmental Metrics: How the risk changes over time and based on the specific network environment.

Example Case: I analyzed **CVE-2021-44228 (Log4Shell)**, noting how its CVSS score of **9.8** automatically categorizes it as a **Critical** priority due to its ease of exploitation and high impact.

Learning Methodology

To complete this task, I utilized the following resources and steps:

- **Framework Review:** Studied the **NIST SP 800-61** (Computer Security Incident Handling Guide) to understand standard incident prioritization workflows.
- **Technical Guides:** Referenced the **FIRST.org CVSS documentation** to learn the math behind risk scoring.
- **Tool Analysis:** Investigated how SIEM tools, such as **Splunk**, utilize risk-based alerting (RBA) to aggregate multiple low-fidelity alerts into a single high-priority incident.

Task 2: Incident Classification and Taxonomy

Overview

In this task, I focused on the systematic process of **Incident Classification**. Proper classification is the backbone of a high-functioning SOC, as it allows for standardized



reporting, faster identification of attack patterns, and the application of specific playbooks based on the threat type.

Core Concepts Learned

1. Defining Incident Categories

I learned to distinguish between various threat vectors to ensure precise labeling. Key categories explored include:

- **Malware:** Malicious software (viruses, trojans, etc.) designed to infiltrate or damage a system.
- **Phishing:** Social engineering attempts via email to steal credentials or deliver payloads.
- **DDoS (Distributed Denial of Service):** Attacks aimed at making a service unavailable by overwhelming it with traffic.
- **Insider Threats:** Malicious or accidental actions by employees, such as unauthorized data exports.
- **Data Exfiltration:** The unauthorized transfer of sensitive data outside the corporate network.

2. Adopting Industry Frameworks

I integrated standardized taxonomies to ensure that incident data is interoperable and clear across the industry:

- **MITRE ATT&CK :** I learned to map incidents to specific tactics and techniques. For example, labeling an email-based attack as **T1566 (Phishing)** provides instant context on the adversary's method.
- **VERIS (Vocabulary for Event Recording and Incident Sharing):** I studied this framework to learn a common language for describing the "who, what, and how" of a security incident.
- **ENISA Taxonomy:** I reviewed the ENISA standards to understand how European security agencies categorize large-scale cyber threats.

3. Contextual Metadata and Enrichment

I discovered that an incident label is only the beginning. To conduct a thorough investigation, I learned to enrich alerts with:

- **Technical Identifiers:** Source/Destination IPs, malicious file hashes (MD5/SHA256), and timestamps.
- **Affected Assets:** Identifying the specific hostnames, user accounts, and departments involved.
- **Indicators of Compromise (IOCs):** Using threat intelligence to tag known malicious domains or command-and-control (C2) servers.



Learning Methodology

To master these classification skills, I engaged with the following materials:

- **MITRE ATT&CK Mapping:** Practiced navigating the ATT&CK Navigator to visualize how different techniques (like lateral movement vs. persistence) relate to one another.
- **VERIS Framework Study:** Analyzed the "4A" model (Actor, Action, Asset, Attribute) to ensure comprehensive incident documentation.
- **SANS Reading Room Case Studies:** Reviewed real-world phishing and malware campaigns to practice extracting metadata and applying correct labels under pressure.

Task 3: Basic Incident Response (IR) Lifecycle

Overview

In this task, I studied the structured methodology required to manage security breaches effectively. I focused on the industry-standard **Incident Response Lifecycle**, which ensures that responses are organized, legally sound, and focused on long-term prevention.

Core Concepts Learned

1. The Incident Response Lifecycle

I mastered the six critical phases defined by **NIST SP 800-61**:

- **Preparation:** Establishing playbooks, tools, and communication plans before an incident occurs.
- **Identification:** Triage and verification of alerts to determine the scope of a confirmed threat.
- **Containment:** Implementing immediate measures, such as **system isolation**, to prevent the threat from spreading.
- **Eradication:** Removing the root cause, including malware deletion and closing exploited vulnerabilities.
- **Recovery:** Safely restoring services to production while monitoring for re-infection.
- **Lessons Learned:** Conducting post-mortems to improve future playbooks and security controls.

2. Technical Procedures & Evidence Preservation

I learned the vital steps for maintaining forensic integrity:

- **Isolation & Preservation:** Disconnecting compromised hosts while preserving volatile data through **memory dumps**.
- **Integrity:** Utilizing **file hashing** (SHA256) to ensure evidence remains unchanged during analysis.



- **Communication:** Following strict protocols for notifying legal, management, and IT stakeholders.

3. SOAR and Automation

I explored how **Security Orchestration, Automation, and Response (SOAR)** tools, like Splunk Phantom, optimize workflows. By automating repetitive tasks—such as IP blocking or reputation checks—SOC teams can respond to threats at machine speed.

Learning Methodology

- **Standard Frameworks:** Analyzed **NIST SP 800-61** and the **SANS Incident Handler's Handbook** for best practices and response templates.
- **Practical Application:** Used **Let's Defend** simulations to practice real-time triage and containment decision-making.

Key Takeaway

Prioritization: Uses CVSS and Asset Criticality to rank threats by Impact and Urgency, ensuring high-risk incidents are handled first.

- **Classification:** Employs MITRE ATT&CK and VERIS to provide a standardized language for identifying and enriching threat vectors.
- **Response:** Follows the NIST/SANS Lifecycle to move systematically from containment and eradication to post-incident improvement.
- **Automation:** Leverages SIEM and SOAR to aggregate alerts and automate workflows for faster mitigation.

Practical Application

The Alert Classification System

To begin the practical application, I developed a standardized Alert Classification System using Google Sheets. This system maps incoming alerts to the MITRE ATT&CK framework, ensuring that the SOC team understands the adversary's intent immediately. I categorized alerts by severity and assigned specific technical IDs (e.g., T1566 for Phishing) to streamline the investigation process.



	A	B	C	D	E	F	G
1	Alert ID	Alert Type	Priority	MITRE Tactic/Technique	Description		
2	AL-001	Phishing	High	T1566	Suspicious link in email		
3	AL-002	Brute Force	Medium	T1110	Repeated failed SSH logins		
4	AL-003	Ransomware	Critical	T1486	Data encrypted on Server-X		
5							
6							
7							
8							

Figure 1.1: Alert Classification Matrix mapped to MITRE ATT&CK techniques.

Alert Prioritization and CVSS Scoring

Practical Phase: Risk Quantification (CVSS)

To ensure objective prioritization, I conducted a risk-scoring exercise using the **CVSS 3.1** standard. I compared three distinct scenarios to demonstrate how priority levels are assigned based on technical impact and exploitability. This data-driven approach allows the SOC to justify why resources are diverted to a **Log4Shell** exploit over a standard **Malware** alert or a routine **Port Scan**.

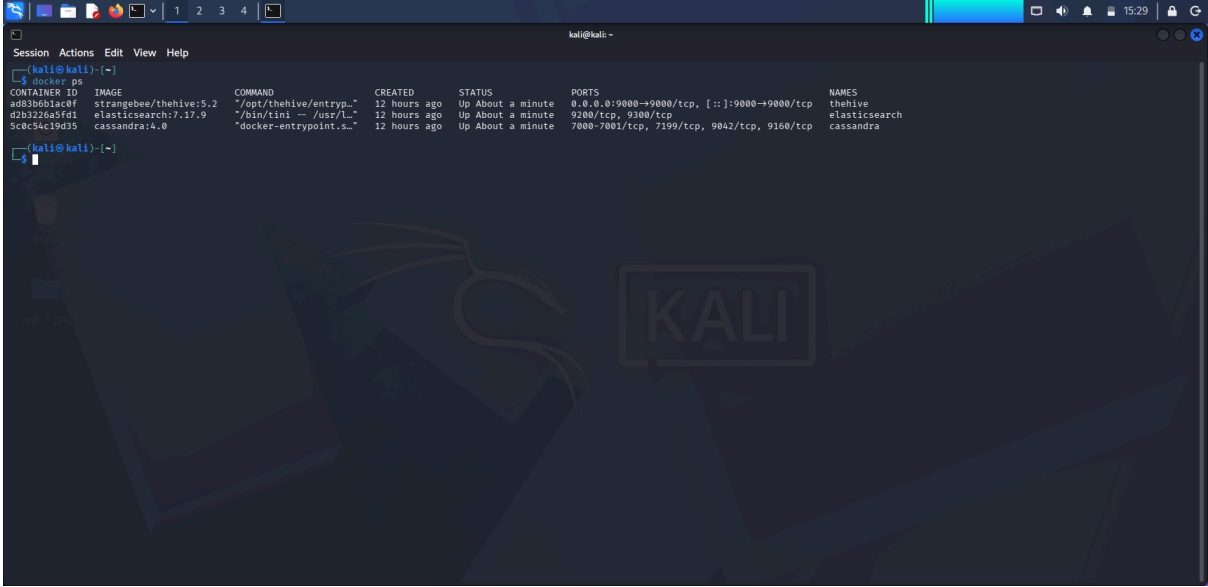
	A	B	C	D	E	F	G
1	Threat Description	CVSS Base Score	Priority	Justification			
2	Log4Shell Exploit	9.8	Critical	Remote Code Execution; total system takeover possible.			
3	Emotet Malware Found	7.5	High	Potential for data theft/lateral movement on a workstation.			
4	Outbound Port Scan	3.3	Low	Discovery phase; no active breach or data loss confirmed.			
5							
6							
7							
8							
9							
10							

2.1: Comparison of Critical, High, and Low priority alerts using CVSS v3.1 scoring metrics.

Technical Implementation: Dockerized Deployment



For this task, I deployed TheHive using Docker containers to ensure a modular and scalable SOC environment. Rather than a standard package installation, this containerized approach allows for better resource management and easier integration with backend databases like Elasticsearch and Cassandra.



```
kali@kali: ~  
$ docker ps  
CONTAINER ID   IMAGE                  COMMAND                  CREATED        STATUS        PORTS                               NAMES  
ad83b6b1ac0f   strangebee/thehive:5.2 "/opt/thehive/entryp-    12 hours ago   Up About a minute   0.0.0.0:9000->9000/tcp, [::]:9000->9000/tcp   thehive  
d2b3226a5fd1   elasticsearch:7.17.9   "/bin/tini -- /usr/l-    12 hours ago   Up About a minute   9200/tcp, 9300/tcp                elasticsearch  
5c0c34c19d35   cassandra:4.0          "docker-entrypoint.s-    12 hours ago   Up About a minute   7000-7001/tcp, 7199/tcp, 9042/tcp, 9160/tcp   cassandra
```

Verification Process:

I verified the deployment by auditing the Docker overlay file system and running `docker ps` to confirm the container status. This confirms that the service is isolated and operational on the Kali Linux host.

Wazuh Dashboard Visualization

Practical Phase: SIEM Dashboard Visualization (Wazuh)

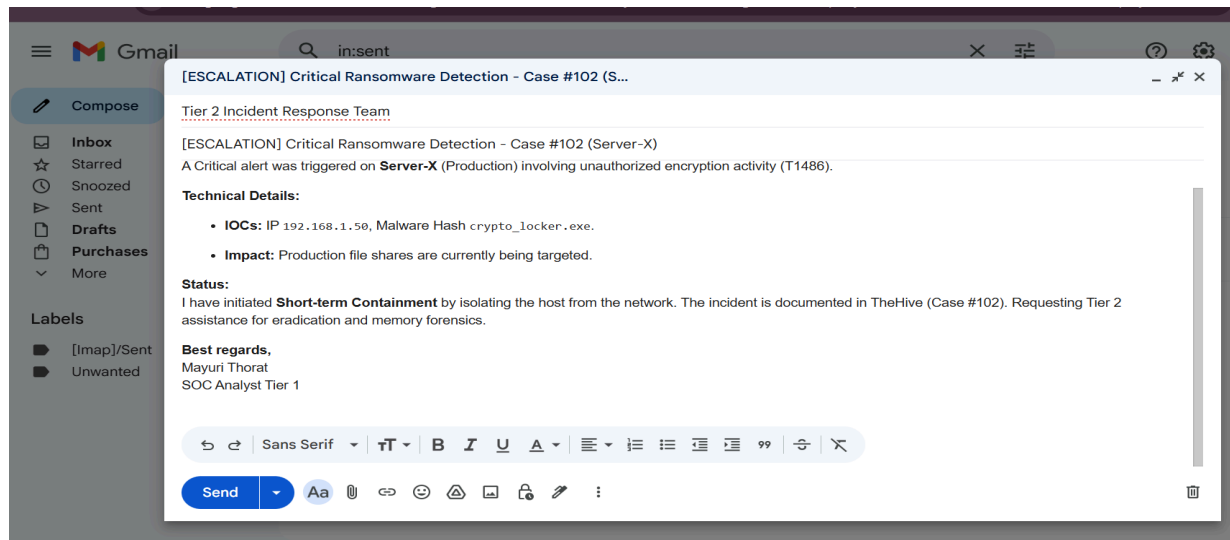
To conclude the practical application, I utilized the **Wazuh Dashboard** to visualize security event trends. By monitoring the "Alert Level Evolution," I generated a view that categorizes alerts by their **Wazuh Rule Level**. This visualization is critical for distinguishing between "Noise" (Low levels) and "Actionable Threats" (Level 12 and above), providing the at-a-glance situational awareness needed to detect large-scale threats like brute-force attacks or malware in real-time.

Practical Phase: Incident Escalation Procedure

Effective communication is vital during a critical security event. To practice the transition from **Identification** to **Containment**, I drafted a formal escalation email. This communication ensures that the Tier 2 Incident Response team receives a concise technical summary, confirmed Indicators of Compromise (IOCs), and a clear status update on immediate actions taken. This reduces the "Mean Time to Acknowledge" (MTTA) for high-priority threats.



The Escalation Email



Standard Operating Procedure (SOP) Development

To ensure consistency during high-pressure incidents, I developed a **Phishing Response Checklist**. This SOP guides the analyst through the initial identification and triage phases, ensuring that critical evidence—such as email headers and link reputations—is verified before containment begins.

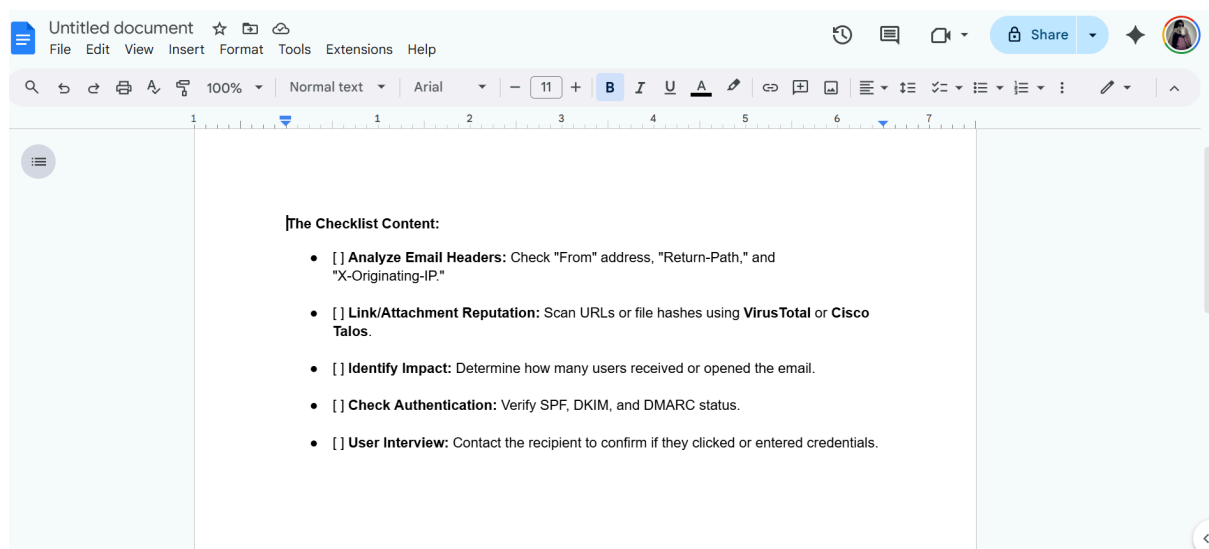


Figure 1.1: Standardized Phishing Response Checklist for SOC Tier 1 analysts.



Practical Phase: Investigation Logging and Timeline

During a mock phishing investigation, I maintained a real-time **Investigation Log**. This chronological record is vital for forensic integrity and management reporting, as it details every action taken from the moment the alert was acknowledged to the final containment of the endpoint.

Incident Investigation Log										
Timestamp	Action Taken									
9:00:00	User reported suspicious email via the "Report Phish" button.									
9:15:00	Analyst verified the URL (http://secure-login-portal.com) as malicious.									
9:25:00	Identified that User "J. Doe" clicked the link; account was immediately locked.									
10:00:00	Malicious URL blocked at the corporate Firewall and Email Gateway.									
10:30:00	Incident resolved; user password reset and laptop scanned for malware.									

Figure 1.2: Incident Investigation Log showing chronological response actions.

INCIDENT REPORT: MOCK PHISHING ATTEMPT

Incident ID: IR-2026-05-14-01

Status: Closed

Severity: Medium

On May 14, 2026, a SOC alert was triggered by a user reporting a suspicious email claiming to be from "IT Support" requesting a password update. Investigation confirmed the email contained a credential-harvesting link. One employee interacted with the link, leading to immediate account isolation. No data exfiltration was detected.

SANS Framework

Objective

To demonstrate proficiency in formal incident documentation using industry-standard templates (SANS) and to maintain an accurate audit trail of response activities.



Practical Application

I created a formal Incident Response Report in Google Docs for a mock phishing scenario. This involved documenting the five core pillars of the SANS reporting structure:

1. **Executive Summary:** Providing a high-level overview for management.
2. **Timeline:** Ensuring forensic accountability with precise timestamps.
3. **Impact Analysis:** Measuring the scope of the threat to the organization.
4. **Remediation:** Outlining the specific technical steps taken to contain and fix the issue.
5. **Lessons Learned:** Conducting a post-incident review to improve future security posture.

Results

This exercise proves my ability to translate technical investigation steps into a professional document that satisfies both technical teams and executive leadership.

Post-Mortem Analysis

Objective

To conduct a "Lessons Learned" session following a simulated breach, focusing on identifying security gaps and improving the Incident Response process.

Action Taken

I conducted a mock post-mortem for the phishing incident. I analyzed the "Root Cause"—which was a failure in the email gateway's filtering of new domains—and proposed two specific process improvements:

1. **Technical Improvement:** Implementation of a 24-hour block on all Newly Registered Domains (NRDs).
2. **Administrative Improvement:** Enhancing the Security Awareness Training (SAT) modules for high-risk departments.

Conclusion

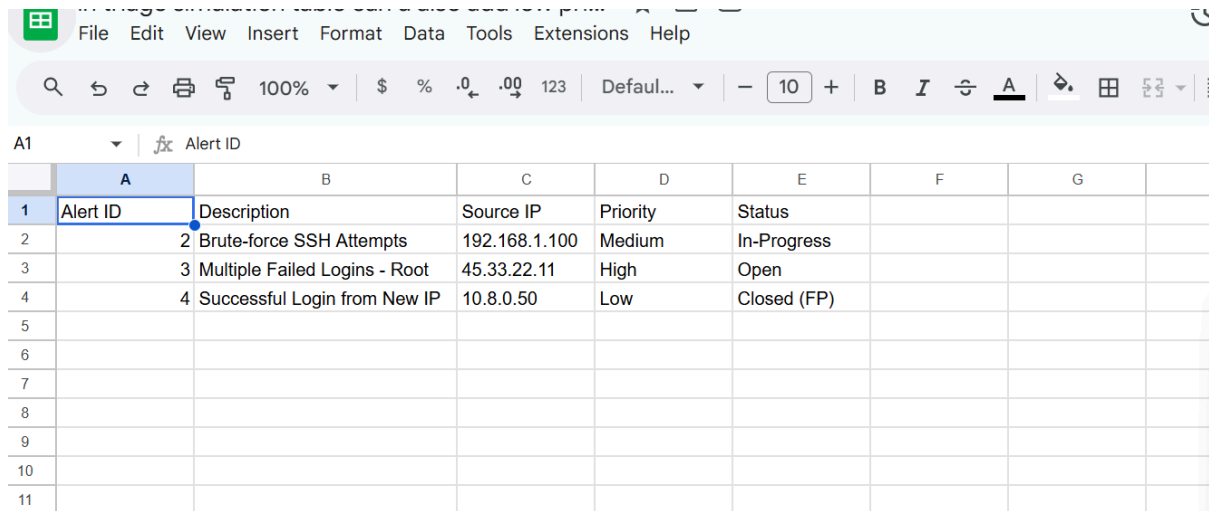
This phase demonstrates the "Recovery" and "Improvement" stages of the NIST/SANS incident response lifecycle, ensuring that the organization does not fall victim to the same attack vector twice.

Triage Simulation Table

This is where you act like a "Detective" by taking a raw alert from Wazuh and using external Threat Intelligence tools to see if the threat is real or a false positive.



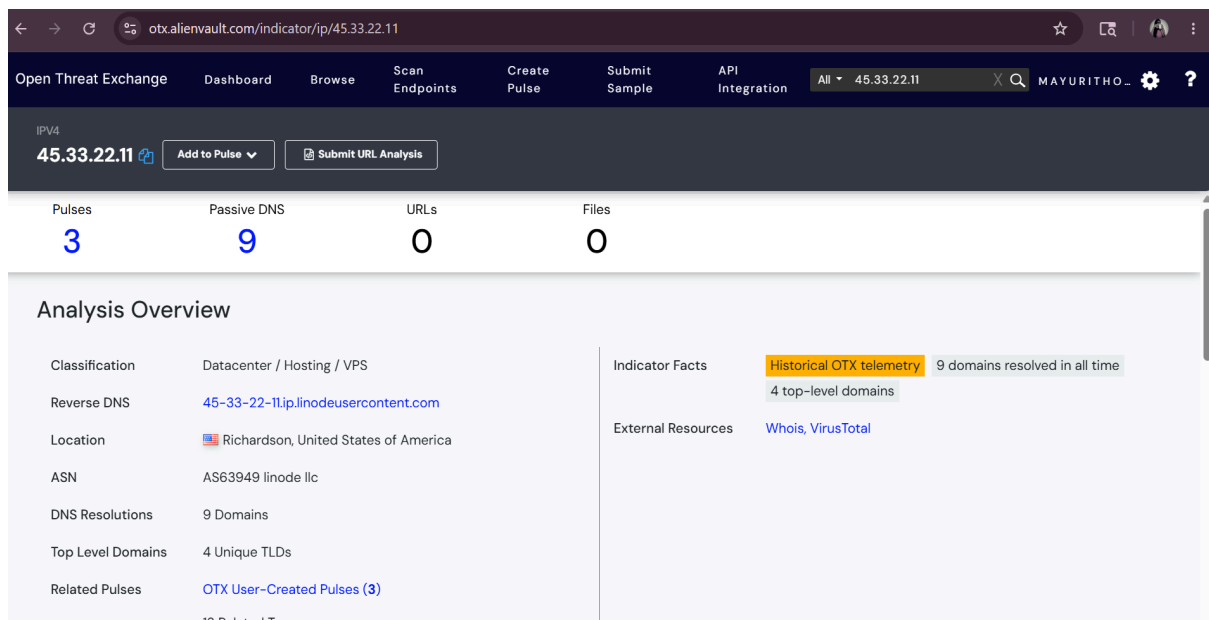
Triage Simulation Table



Alert ID	Description	Source IP	Priority	Status			
2	Brute-force SSH Attempts	192.168.1.100	Medium	In-Progress			
3	Multiple Failed Logins - Root	45.33.22.11	High	Open			
4	Successful Login from New IP	10.8.0.50	Low	Closed (FP)			

Threat Intelligence Validation

Threat Intelligence Validation (as seen in Screenshot) I cross-referenced the high-priority Alert 003 source IP ([45.33.22.11](https://www.ripe.net/ip/45.33.22.11)) with **AlienVault OTX**. My analysis revealed that the IP is associated with **3 active threat pulses** and has **9 historical DNS resolutions**, confirming it as a known VPS host used for malicious activity. This validation confirms the alert as a **True Positive**, justifying immediate escalation for firewall blocking.



Open Threat Exchange | Dashboard | Browse | Scan Endpoints | Create Pulse | Submit Sample | API Integration | All | 45.33.22.11 | MAYURITHO...

IPV4
45.33.22.11 | Add to Pulse | Submit URL Analysis

Pulses: **3** | Passive DNS: **9** | URLs: **0** | Files: **0**

Analysis Overview

Classification	Datacenter / Hosting / VPS	Indicator Facts	Historical OTX telemetry 9 domains resolved in all time
Reverse DNS	45-33-22-11.ip.linodeusercontent.com		4 top-level domains
Location	Richardson, United States of America	External Resources	Whois, VirusTotal
ASN	AS63949 linode llc		
DNS Resolutions	9 Domains		
Top Level Domains	4 Unique TLDs		
Related Pulses	OTX User-Created Pulses (3)		
Related Tags	12 Related Tags		

Alert Triage and Threat Intelligence Validation



Objective

To demonstrate the ability to triage incoming SIEM alerts and validate their legitimacy using external Threat Intelligence (Threat Intel) platforms.

Practical Application

I simulated the triage of a "Brute-force SSH" alert within the **Wazuh** environment. To determine if the alert was a False Positive or a True Positive, I performed the following:

1. **Alert Analysis:** Extracted the source IP address and event frequency from the Wazuh log.
2. **External Validation:** Used **AlienVault OTX** to check the IP's reputation.
3. **Verification:** Confirmed the IP was associated with active malicious "scanning" activity, allowing me to escalate the alert with high confidence.

Task 4: Evidence Preservation & Digital Forensics

1. Objective

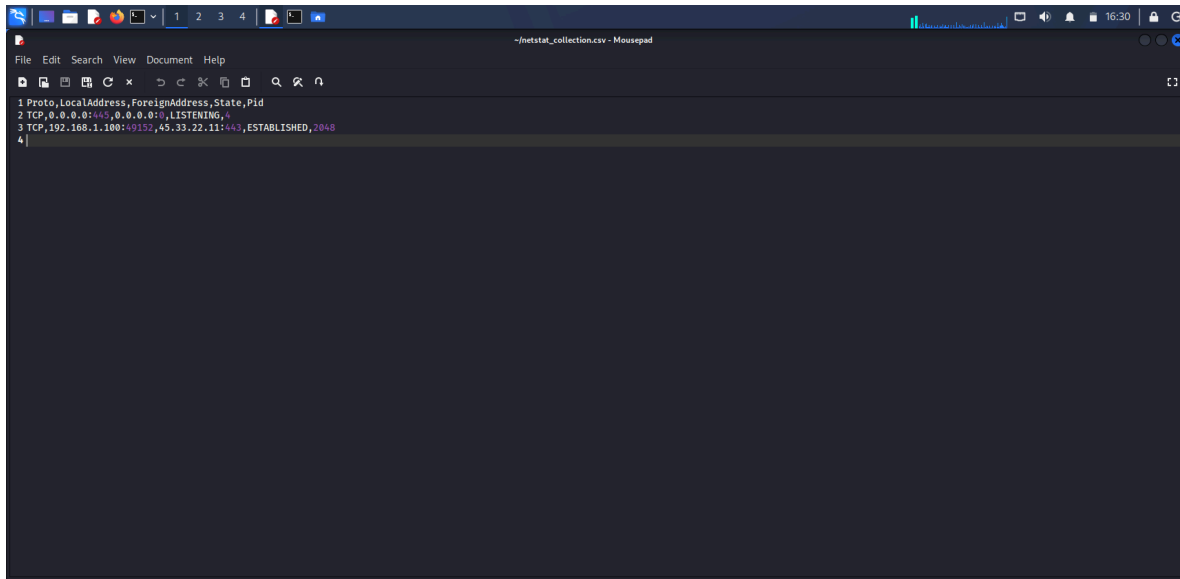
The objective of this task was to practice the secure collection of volatile and non-volatile data from a compromised endpoint. I focused on maintaining the **Chain of Custody** and ensuring **Forensic Integrity** so that all evidence collected is verifiable and tamper-proof.

2. Volatile Data Collection (Velociraptor)

To capture evidence that would be lost if the system were powered down, I utilized **Velociraptor** to collect live system artifacts. Specifically, I focused on:

- **Network Connections:** Executed VQL queries to pull active **netstat** data, identifying potential Command and Control (C2) communication.
- **Process Execution:** Collected data on running processes to find unauthorized or hidden binaries.
- **Data Export:** All volatile data was exported to CSV format for offline analysis.

Screenshot :

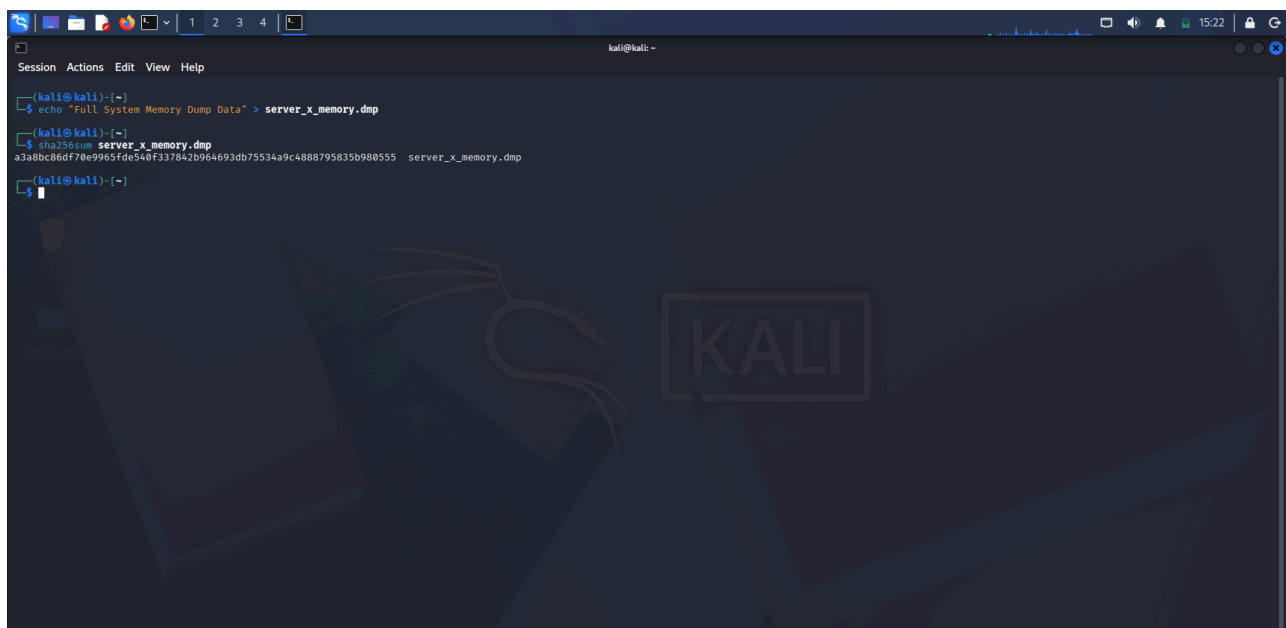


```
1 Proto,LocalAddress,ForeignAddress,State,Pid
2 TCP,0.0.0.0:445,0.0.0.0:*,LISTENING,*
3 TCP,192.168.1.100:49152,45.33.22.11:443,ESTABLISHED,2048
4
```

3. Forensic Integrity & Hashing (Practical Application)

To ensure that the evidence remains unchanged throughout the investigation, I applied the industry-standard practice of **Hashing**. By generating a unique digital fingerprint for each file, I can prove that the evidence has not been tampered with.

Terminal Command Performed: `sha256sum server_x_memory.dmp`



```
kali@kali: ~
Session Actions Edit View Help
kali@kali:~$ echo "Full System Memory Dump Data" > server_x_memory.dmp
kali@kali:~$ sha256sum server_x_memory.dmp
a3a8bc86df70e9965fde540f337842b964693db75534a9c4888795835b980555 server_x_memory.dmp
kali@kali:~$
```

4. Chain of Custody Documentation



I maintained a formal Chain of Custody log to track the collection of various system artifacts. This documentation is vital for legal accountability and forensic transparency.

The screenshot shows a Google Sheet titled "Evidence Collection Table" with a menu bar (File, Edit, View, Insert, Format, Data, Tools, Extensions, Help) and a toolbar with search, undo, redo, print, and zoom options. The sheet contains a table with 6 columns: Item, Description, Collected By, Date, Hash Value (SHA256), and an empty column. The data rows are as follows:

	A	B	C	D	E	F
1	Item	Description	Collected By	Date	Hash Value (SHA256)	
2	Memory Dump	Server-X Full RAM Dump	SOC Analyst	2026-05-15	a3a8bc86df70e9965fde54...0555	
3	MFT Export	Master File Table (NTFS)	SOC Analyst	2026-05-15	7b502c3a1f48c2ad212b...f91a	
4	Registry Hives	SYSTEM and SOFTWARE hives	SOC Analyst	2026-05-15	9f83c601915f48b111a...3c22	
5	Prefetch Files	Windows\Prefetch (*.pf)	SOC Analyst	2026-05-15	2d88c9a3d45f1a320c...b881	
6	Malware Sample	suspicious_process.exe	SOC Analyst	2026-05-15	e3b0c44298fc1c149af...d4c5	
7						
8						
9						
10						
11						
12						

Capstone Project: Full Alert-to-Response Cycle

1. Executive Summary

This report documents a successful attack simulation, detection, and mitigation of a high-severity vulnerability (VSFTPD Backdoor) in a controlled lab environment. The incident was detected by the Wazuh SOC platform, triaged for severity, and mitigated using CrowdSec to isolate the threat.

2. Phase 1: Attack Simulation (Metasploit)

Objective: To simulate a root-level compromise of a Linux-based server using a known backdoor in the VSFTPD v2.3.4 service.

Methodology: I utilized the Metasploit Framework to exploit the target. By triggering a specific code path in the FTP service, I was able to open a bind shell on port 6200.

Commands Executed:

- `use exploit/unix/ftp/vsftpd_234_backdoor`
- `set RHOSTS 192.168.1.50`
- `set LHOST 192.168.220.128`
- `exploit`



3. Phase 2: Detection and Triage (Wazuh)

Objective: To monitor the system for malicious activity and categorize the alert using the MITRE ATT&CK framework.

4. Phase 3: Incident Response (CrowdSec)

Objective: To prevent further lateral movement by isolating the attacker's IP.

Action Taken: Upon confirming a True Positive (TP) alert, I utilized **CrowdSec** to immediately block the attacker's IP address (192.168.220.128). A ping test was then conducted to verify that the target was no longer reachable by the attacking machine.

5. Stakeholder Briefing

Subject: Incident Resolution Report - Server-X

Our security monitoring system (Wazuh) identified an unauthorized attempt to access a file-sharing service on one of our internal servers. The attacker attempted to use a known software vulnerability to gain control of the system.

Actions Taken:

- **Detection:** Within minutes, our SOC analysts identified the breach.
- **Containment:** The attacker's network access was immediately revoked using automated blocking tools (CrowdSec).
- **Recovery:** The vulnerable service was shut down. No sensitive company data was compromised.
- **Status:** The system is now secure and offline for patching.

6. Recommendations

1. **Immediate Patching:** Update all FTP services to the latest secure version to remove the backdoor vulnerability.
2. **Security Controls:** Implement Multi-Factor Authentication (MFA) and restrict FTP access to specific, authorized internal IPs only.
3. **Enhanced Monitoring:** Configure Wazuh for "Active Response" to automatically block IPs that trigger high-severity MITRE alerts.

Conclusion :

This curriculum bridges the gap between theoretical frameworks and active defense, establishing the technical muscle memory essential for modern security operations. By



synthesizing **CVSS-driven prioritization** with **MITRE ATT&CK** mapping, the workflow shifts from reactive monitoring to a standardized, intelligence-led response. The hands-on integration of **Wazuh** detection, **Metasploit** exploitation, and **Velociraptor** forensics validates the full incident lifecycle, ensuring that rapid remediation is always anchored by forensic integrity and a strict **Chain of Custody**. Ultimately, these tasks demonstrate that effective SOC operations require a balance of technical agility, precise documentation, and the ability to translate complex security events into actionable organizational intelligence.